

サンプル問題

新試験開始直前の2022年（令和4年）12月26日に、情報処理推進機構（IPA）が公開した「サンプル問題」の問題と解説を掲載しています。

科目A（問1～問48）、科目B（問49～問60）ともに実践的な内容です。試験時間120分以内で解答できるか、時間を計測して挑戦するとよいでしょう。

- **付録 Webアプリ**

本書掲載のすべての練習問題・模擬問題〈科目A〉・サンプル問題〈科目A〉のWebアプリをご利用できます。詳しくはp.027をご覧ください。

▶ サンプル問題 〈科目A〉



出題数：48問（全問解答必須）

試験時間：120分（両科目）

問1 JIS Q 27001:2014（情報セキュリティマネジメントシステム—要求事項）において、リスクを受容するプロセスに求められるものはどれか。（解説p.531）

- ア 受容するリスクについては、リスク所有者が承認すること
- イ 受容するリスクを監視やレビューの対象外とすること
- ウ リスクの受容は、リスク分析前に行うこと
- エ リスクを受容するかどうかは、リスク対応後に決定すること

問2 退職する従業員による不正を防ぐための対策のうち、IPA“組織における内部不正防止ガイドライン（第5版）”に照らして、適切なものはどれか。（解説p.531）

- ア 在職中に知り得た重要情報を退職後に公開しないように、退職予定者に提出させる秘密保持誓約書には、秘密保持の対象を明示せず、重要情報を客観的に特定できないようにしておく。
- イ 退職後、同業他社に転職して重要情報を漏らすということがないように、職業選択の自由を行使しないことを明記した上で、具体的な範囲を設定しない包括的な競業禁止義務契約を入社時に締結する。
- ウ 退職者による重要情報の持出しなどの不正行為を調査できるように、従業員に付与した利用者IDや権限は退職後も有効にしておく。
- エ 退職間際に重要情報の不正な持出しが行われやすいので、退職予定者に対する重要情報へのアクセスや媒体の持出しの監視を強化する。

問3 JIS Q 27000:2019（情報セキュリティマネジメントシステム—用語）において、不適合が発生した場合にその原因を除去し、再発を防止するためのものとして定義されているものはどれか。（解説p.531）

- ア 継続的改善
- イ 修正
- ウ 是正処置
- エ リスクアセスメント

問4 JIS Q 27002:2014（情報セキュリティ管理策の実践のための規範）の“サポートユーティリティ”に関する例示に基づいて、サポートユーティリティと判断されるものはどれか。（解説p.532）

- ア サーバ室の空調
- イ サーバの保守契約
- ウ 特権管理プログラム
- エ ネットワーク管理者

問5 JIS Q 27000:2019（情報セキュリティマネジメントシステム—用語）における“リスクレベル”の定義はどれか。（解説p.532）

- ア 脅威によって付け込まれる可能性のある、資産又は管理策の弱点
- イ 結果とその起こりやすさの組合せとして表現される、リスクの大きさ
- ウ 対応すべきリスクに付与する優先順位
- エ リスクの重大性を評価するために目安とする条件

問6 サイバーセキュリティ基本法に基づき、内閣にサイバーセキュリティ戦略本部が設置されたのと同時に、内閣官房に設置された組織はどれか。（解説p.532）

- ア IPA
- イ JIPDEC
- ウ JPCERT/CC
- エ NISC

問7 CRYPTRECの役割として、適切なものはどれか。

(解説p.533)

- ア 外国為替及び外国貿易法で規制されている暗号装置の輸出許可申請を審査、承認する。
- イ 政府調達においてIT関連製品のセキュリティ機能の適切性を評価、認証する。
- ウ 電子政府での利用を推奨する暗号技術の安全性を評価、監視する。
- エ 民間企業のサーバに対するセキュリティ攻撃を監視、検知する。

問8 緊急事態を装って組織内部の人間からパスワードや機密情報を入手する不正な行為は、どれに分類されるか。
(解説p.533)

- | | |
|-----------------|--------------|
| ア ソーシャルエンジニアリング | イ トロイの木馬 |
| ウ 踏み台攻撃 | エ ブルートフォース攻撃 |

問9 A社では現在、インターネット上のWebサイトを内部ネットワークのPC上のWebブラウザから参照している。新たなシステムを導入し、DMZ上に用意したVDI (Virtual Desktop Infrastructure) サーバにPCからログインし、インターネット上のWebサイトをVDIサーバ上の仮想デスクトップのWebブラウザから参照するように変更する。この変更によって期待できるセキュリティ上の効果はどれか。

(解説p.533)

- ア インターネット上のWebサイトから、内部ネットワークのPCへのマルウェアのダウンロードを防ぐ。
- イ インターネット上のWebサイト利用時に、MITB攻撃による送信データの改ざんを防ぐ。
- ウ 内部ネットワークのPC及び仮想デスクトップのOSがボットに感染しなくなり、C&Cサーバにコントロールされることを防ぐ。
- エ 内部ネットワークのPCにマルウェアが侵入したとしても、他のPCに感染するのを防ぐ。

問10 デジタルフォレンジックスでハッシュ値を利用する目的として、適切なものはどれか。(解説 p.534)

- ア 一方向性関数によってパスワードを復元できないように変換して保存する。
- イ 改変されたデータを、証拠となり得るように復元する。
- ウ 証拠となり得るデータについて、原本と複製の同一性を証明する。
- エ パスワードの盗聴の有無を検証する。

問11 利用者PCの内蔵ストレージが暗号化されていないとき、攻撃者が利用者PCから内蔵ストレージを抜き取り、攻撃者が用意したPCに接続して内蔵ストレージ内の情報を盗む攻撃の対策に該当するものはどれか。(解説 p.534)

- ア 内蔵ストレージにインストールしたOSの利用者アカウントに対して、ログインパスワードを設定する。
- イ 内蔵ストレージに保存したファイルの読取り権限を、ファイルの所有者だけに付与する。
- ウ 利用者PC上でHDDパスワードを設定する。
- エ 利用者PCにBIOSパスワードを設定する。

問12 ルートキットの特徴はどれか。(解説 p.534)

- ア OSなどに不正に組み込んだツールの存在を隠す。
- イ OSの中核であるカーネル部分の脆弱性を分析する。
- ウ コンピュータがマルウェアに感染していないことをチェックする。
- エ コンピュータやルータのアクセス可能な通信ポートを外部から調査する。

問13 BEC (Business E-mail Compromise) に該当するものはどれか。 (解説p.535)

- ア 巧妙なだましの手口を駆使し、取引先になりすまして偽の電子メールを送り、金銭をだまし取る。
- イ 送信元を攻撃対象の組織のメールアドレスに詐称し、多数の実在しないメールアドレスに一度に大量の電子メールを送り、攻撃対象の組織のメールアドレスを故意にブラックリストに登録させて、利用を阻害する。
- ウ 第三者からの電子メールが中継できるように設定されたメールサーバを、スパムメールの中継に悪用する。
- エ 誹謗中傷メールの送信元を攻撃対象の組織のメールアドレスに詐称し、組織の社会的な信用を大きく損なわせる。

問14 ボットネットにおけるC&Cサーバの役割として、適切なものはどれか。

(解説p.535)

- ア Webサイトのコンテンツをキャッシュし、本来のサーバに代わってコンテンツを利用者に配信することによって、ネットワークやサーバの負荷を軽減する。
- イ 外部からインターネットを経由して社内ネットワークにアクセスする際に、CHAPなどのプロトコルの中継することによって、利用者認証時のパスワードの盗聴を防止する。
- ウ 外部からインターネットを経由して社内ネットワークにアクセスする際に、時刻同期方式を採用したワンタイムパスワードを発行することによって、利用者認証時のパスワードの盗聴を防止する。
- エ 侵入して乗っ取ったコンピュータに対して、他のコンピュータへの攻撃などの不正な操作をするよう、外部から命令を出したり応答を受け取ったりする。

問15 PCへの侵入に成功したマルウェアがインターネット上の指令サーバと通信を行う場合に、宛先ポートとして使用されるTCPポート番号80に関する記述のうち、適切なものはどれか。
(解説p.535)

- ア DNSのゾーン転送に使用されることから、通信がファイアウォールで許可されている可能性が高い。
- イ WebサイトのHTTPS通信での閲覧に使用されることから、マルウェアと指令サーバとの間の通信が侵入検知システムで検知される可能性が低い。
- ウ Webサイトの閲覧に使用されることから、通信がファイアウォールで許可されている可能性が高い。
- エ ドメイン名の名前解決に使用されることから、マルウェアと指令サーバとの間の通信が侵入検知システムで検知される可能性が低い。

問16 特定のサービスやシステムから流出した認証情報を攻撃者が用いて、認証情報を複数のサービスやシステムで使い回している利用者のアカウントへのログインを試みる攻撃はどれか。
(解説p.536)

- ア パスワードリスト攻撃
- イ ブルートフォース攻撃
- ウ リバースブルートフォース攻撃
- エ レインボーテーブル攻撃

問17 攻撃者が用意したサーバXのIPアドレスが、A社WebサーバのFQDNに対応するIPアドレスとして、B社DNSキャッシュサーバに記憶された。これによって、意図せずサーバXに誘導されてしまう利用者はどれか。ここで、A社、B社の各従業員は自社のDNSキャッシュサーバを利用して名前解決を行う。
(解説p.536)

- ア A社WebサーバにアクセスしようとするA社従業員
- イ A社WebサーバにアクセスしようとするB社従業員
- ウ B社WebサーバにアクセスしようとするA社従業員
- エ B社WebサーバにアクセスしようとするB社従業員

問18 攻撃者が、多数のオープンリゾルバに対して、“あるドメイン”の存在しないランダムなサブドメインを多数問い合わせる攻撃（ランダムサブドメイン攻撃）を仕掛け、多数のオープンリゾルバが応答した。このときに発生する事象はどれか。

（解説p.537）

- ア “あるドメイン”を管理する権威DNSサーバに対して負荷が掛かる。
- イ “あるドメイン”を管理する権威DNSサーバに登録されているDNS情報が改ざんされる。
- ウ オープンリゾルバが保持するDNSキャッシュに不正な値を注入される。
- エ オープンリゾルバが保持するゾーン情報を不正に入手される。

問19 SEO ポイズニングの説明はどれか。

（解説p.537）

- ア Web 検索サイトの順位付けアルゴリズムを悪用して、検索結果の上位に、悪意のある Web サイトを意図的に表示させる。
- イ 車などで移動しながら、無線 LAN のアクセスポイントを探し出して、ネットワークに侵入する。
- ウ ネットワークを流れるパケットから、侵入のパターンに合致するものを検出して、管理者への通知や、検出した内容の記録を行う。
- エ マルウェア対策ソフトのセキュリティ上の脆弱性を悪用して、システム権限で不正な処理を実行させる。

問20 データベースで管理されるデータの暗号化に用いることができ、かつ、暗号化と復号とで同じ鍵を使用する暗号方式はどれか。

（解説p.537）

- ア AES
- イ PKI
- ウ RSA
- エ SHA-256

問21 OpenPGP や S/MIME において用いられるハイブリッド暗号方式の特徴はどれか。
(解説 p.537)

- ア 暗号通信方式として IPsec と TLS を選択可能にすることによって利用者の利便性を高める。
- イ 公開鍵暗号方式と共通鍵暗号方式を組み合わせることによって鍵管理コストと処理性能の両立を図る。
- ウ 複数の異なる共通鍵暗号方式を組み合わせることによって処理性能を高める。
- エ 複数の異なる公開鍵暗号方式を組み合わせることによって安全性を高める。

問22 デジタル署名に用いる鍵の組みのうち、適切なものはどれか。
(解説 p.537)

	デジタル署名の 作成に用いる鍵	デジタル署名の 検証に用いる鍵
ア	共通鍵	秘密鍵
イ	公開鍵	秘密鍵
ウ	秘密鍵	共通鍵
エ	秘密鍵	公開鍵

問23 メッセージが改ざんされていないかどうかを確認するために、そのメッセージから、ブロック暗号を用いて生成することができるものはどれか。
(解説 p.538)

- ア PKI
- イ パリティビット
- ウ メッセージ認証符号
- エ ルート証明書

問24 リスクベース認証に該当するものはどれか。

(解説p.538)

- ア インターネットバンキングでの取引において、取引の都度、乱数表の指定したマス目にある英数字を入力させて認証する。
- イ 全てのアクセスに対し、トークンで生成されたワンタイムパスワードを入力させて認証する。
- ウ 利用者のIPアドレスなどの環境を分析し、いつもと異なるネットワークからのアクセスに対して追加の認証を行う。
- エ 利用者の記憶、持ち物、身体の特徴のうち、必ず二つ以上の方式を組み合わせで認証する。

問25 Webサイトで利用されるCAPTCHAに該当するものはどれか。

(解説p.538)

- ア 人からのアクセスであることを確認できるよう、アクセスした者に応答を求め、その応答を分析する仕組み
- イ 不正なSQL文をデータベースに送信しないよう、Webサーバに入力された文字列をブレースホルダに割り当ててSQL文を組み立てる仕組み
- ウ 利用者が本人であることを確認できるよう、Webサイトから一定時間ごとに異なるパスワードを要求する仕組み
- エ 利用者が本人であることを確認できるよう、乱数をWebサイト側で生成して利用者に送り、利用者側でその乱数を鍵としてパスワードを暗号化し、Webサイトに送り返す仕組み

問26 HTTP over TLS (HTTPS) を用いて実現できるものはどれか。

(解説p.539)

- ア Webサーバ上のファイルの改ざん検知
- イ Webブラウザが動作するPC上のマルウェア検査
- ウ Webブラウザが動作するPCに対する侵入検知
- エ デジタル証明書によるサーバ認証

問27 SPF (Sender Policy Framework) を利用する目的はどれか。 (解説p.539)

- ア HTTP 通信の経路上での中間者攻撃を検知する。
- イ LAN への PC の不正接続を検知する。
- ウ 内部ネットワークへの侵入を検知する。
- エ メール送信者のドメインのなりすましを検知する。

問28 電子メールをドメイン A の送信者がドメイン B の宛先に送信するとき、送信者をドメイン A のメールサーバで認証するためのものはどれか。 (解説p.539)

- ア APOP イ POP3S ウ S/MIME エ SMTP-AUTH

問29 マルウェアの動的解析に該当するものはどれか。 (解説p.539)

- ア 検体のハッシュ値を計算し、オンラインデータベースに登録された既知のマルウェアのハッシュ値のリストと照合してマルウェアを特定する。
- イ 検体をサンドボックス上で実行し、その動作や外部との通信を観測する。
- ウ 検体をネットワーク上の通信データから抽出し、さらに、逆コンパイルして取得したコードから検体の機能を調べる。
- エ ハードディスク内のファイルの拡張子とファイルヘッダの内容を基に、拡張子が偽装された不正なプログラムファイルを検出する。

問30 Web サーバの検査におけるポートスキャナの利用目的はどれか。 (解説p.540)

- ア Web サーバで稼働しているサービスを列挙して、不要なサービスが稼働していないことを確認する。
- イ Web サーバの利用者 ID の管理状況を運用者に確認して、情報セキュリティポリシーからの逸脱がないことを調べる。
- ウ Web サーバへのアクセスの履歴を解析して、不正利用を検出する。
- エ 正規の利用者 ID でログインし、Web サーバのコンテンツを直接確認して、コンテンツの脆弱性を検出する。

問31 個人情報保護委員会“特定個人情報の適正な取扱いに関するガイドライン（事業者編）令和4年3月一部改正”及びその“Q&A”によれば、事業者によるファイル作成が禁止されている場合はどれか。

なお、“Q&A”とは“「特定個人情報の適正な取扱いに関するガイドライン（事業者編）」及び「（別冊）金融業務における特定個人情報の適正な取扱いに関するガイドライン」に関するQ&A令和4年4月1日更新”のことである。（解説p.540）

- ア システム障害に備えた特定個人情報ファイルのバックアップファイルを作成する場合
- イ 従業員の個人番号を利用して業務成績を管理するファイルを作成する場合
- ウ 税務署に提出する資料間の整合性を確認するために個人番号を記載した明細表などチェック用ファイルを作成する場合
- エ 保険契約者の死亡保険金支払に伴う支払調書ファイルを作成する場合

問32 企業が業務で使用しているコンピュータに、記憶媒体を介してマルウェアを侵入させ、そのコンピュータのデータを消去した者を処罰の対象とする法律はどれか。

（解説p.540）

- | | |
|-------------|--------------|
| ア 刑法 | イ 製造物責任法 |
| ウ 不正アクセス禁止法 | エ プロバイダ責任制限法 |

問33 企業が、“特定電子メールの送信の適正化等に関する法律”に定められた特定電子メールに該当する広告宣伝メールを送信する場合に関する記述のうち、適切なものはどれか。（解説p.541）

- ア SMSで送信する場合はオプトアウト方式を利用する。
- イ オプトイン方式、オプトアウト方式のいずれかを企業が自ら選択する。
- ウ 原則としてオプトアウト方式を利用する。
- エ 原則としてオプトイン方式を利用する。

問34 A社は、B社と著作物の権利に関する特段の取決めをせず、A社の要求仕様に基づいて、販売管理システムのプログラム作成をB社に委託した。この場合のプログラム著作権の原始的帰属に関する記述のうち、適切なものはどれか。 (解説p.541)

- ア A社とB社が話し合って帰属先を決定する。
- イ A社とB社の共有帰属となる。
- ウ A社に帰属する。
- エ B社に帰属する。

問35 システムテストの監査におけるチェックポイントのうち、最も適切なものはどれか。 (解説p.541)

- ア テストケースが網羅的に想定されていること
- イ テスト計画は利用者側の責任者だけで承認されていること
- ウ テストは実際に業務が行われている環境で実施されていること
- エ テストは利用者側の担当者だけで行われていること

問36 アクセス制御を監査するシステム監査人の行為のうち、適切なものはどれか。 (解説p.542)

- ア ソフトウェアに関するアクセス制御の管理台帳を作成し、保管した。
- イ データに関するアクセス制御の管理規程を閲覧した。
- ウ ネットワークに関するアクセス制御の管理方針を制定した。
- エ ハードウェアに関するアクセス制御の運用手続を実施した。

問37 我が国の証券取引所に上場している企業において、内部統制の整備及び運用に最終的な責任を負っている者は誰か。 (解説p.542)

- ア 株主
- イ 監査役
- ウ 業務担当者
- エ 経営者

問38 ヒューマンエラーに起因する障害を発生しにくくする方法に、エラープルーフ化がある。運用作業におけるエラープルーフ化の例として、最も適切なものはどれか。
(解説p.542)

- ア 画面上の複数のウィンドウを同時に使用する作業では、ウィンドウを間違えないようにウィンドウの背景色をそれぞれ異なる色にする。
- イ 長時間に及ぶシステム監視作業では、疲労が蓄積しないように、2時間おきに交代で休憩を取得する体制にする。
- ウ ミスが発生しやすい作業について、過去に発生したヒヤリハット情報を共有して同じミスを起こさないようにする。
- エ 臨時の作業を行う際にも落ち着いて作業ができるように、臨時の作業の教育や訓練を定期的に行う。

問39 あるデータセンタでは、受発注管理システムの運用サービスを提供している。次の受発注管理システムの運用中の事象において、インシデントに該当するものはどれか。
(解説p.542)

〔受発注管理システムの運用中の事象〕

夜間バッチ処理において、注文トランザクションデータから注文書出力するプログラムが異常終了した。異常終了を検知した運用担当者から連絡を受けた保守担当者は、緊急出社してサービスを回復し、後日、異常終了の原因となったプログラムの誤りを修正した。

- | | |
|--------------|--------------|
| ア 異常終了の検知 | イ プログラムの誤り |
| ウ プログラムの異常終了 | エ 保守担当者の緊急出社 |

問40 ソフトウェア開発プロジェクトにおいてWBSを作成する目的として、適切なものはどれか。
(解説p.543)

- ア 開発の期間と費用とがトレードオフの関係にある場合に、総費用の最適化を図る。
- イ 作業の順序関係を明確にして、重点管理すべきクリティカルパスを把握する。
- ウ 作業の日程を横棒（バー）で表して、作業の開始時点や終了時点、現時点の進捗を明確にする。
- エ 作業を、階層的に詳細化して、管理可能な大きさに細分化する。

問41 プロジェクトの日程計画を作成するのに適した技法はどれか。
(解説p.543)

- ア PERT
- イ 回帰分析
- ウ 時系列分析
- エ 線形計画法

問42 一方のコンピュータが正常に機能しているときには、他方のコンピュータが待機状態にあるシステムはどれか。
(解説p.543)

- ア デュアルシステム
- イ デュプレックスシステム
- ウ マルチプロセッシングシステム
- エ ロードシェアシステム

問43 データベースの監査ログを取得する目的として、適切なものはどれか。
(解説p.544)

- ア 権限のない利用者のアクセスを拒否する。
- イ チェックポイントからのデータ復旧に使用する。
- ウ データの不正な書換えや削除を事前に検知する。
- エ 問題のあるデータベース操作を事後に調査する。

問44 社内ネットワークのPCから、中継装置を経由してインターネット上のWebサーバにアクセスする。中継装置は宛先のWebサーバのドメイン名からDNSを利用してグローバルIPアドレスを求め、そのグローバルIPアドレス宛てにアクセス要求の転送を行う機能を有する。この中継装置として、適切なものはどれか。 (解説p.544)

- | | |
|-----------|------------|
| ア プロキシサーバ | イ リピータ |
| ウ ルータ | エ レイヤ2スイッチ |

問45 BP0の説明はどれか。 (解説p.544)

- ア 災害や事故で被害を受けても、重要事業を中断させない、又は可能な限り中断期間を短くする仕組みを構築すること
- イ 社内業務のうちコアビジネスでない事業に関わる業務の一部又は全部を、外部の専門的な企業に委託すること
- ウ 製品の基準生産計画、部品表及び在庫情報を基に、資材の所要量と必要な時期を求め、これを基準に資材の手配、納入の管理を支援する生産管理手法のこと
- エ プロジェクトを、戦略との適合性や費用対効果、リスクといった観点から評価を行い、情報化投資のバランスを管理し、最適化を図ること

問46 製造業の企業が社会的責任を果たす活動の一環として、雇用創出や生産設備の環境対策に投資することによって、便益を享受するステークホルダは、株主、役員、従業員に加えて、どれか。 (解説p.545)

- | | |
|----------------|---------------|
| ア 近隣地域社会の住民 | イ 原材料の輸入元企業 |
| ウ 製品を購入している消費者 | エ 取引をしている下請企業 |

- 問47 表から、期末在庫品を先入先出法で評価した場合の期末の在庫評価額は何千円か。
(解説p.545)

摘要		数量（個）	単価（千円）
期首在庫		10	10
仕入	4月	1	11
	6月	2	12
	7月	3	13
	9月	4	14
期末在庫		12	

- ア 132 イ 138 ウ 150 エ 168

- 問48 製造原価明細書から損益計算書を作成したとき、売上総利益は何千円か。
(解説p.546)

単位 千円		単位 千円	
製造原価明細書		損益計算書	
材料費	400	売上高	1,000
労務費	300	売上原価	
経 費	200	期首製品棚卸高	120
当期総製造費用		当期製品製造原価	
期首仕掛品棚卸高	150	期末製品棚卸高	70
期末仕掛品棚卸高	250	売上原価	
当期製品製造原価		売上総利益	

- ア 150 イ 200 ウ 310 エ 450

▶ サンプル問題 〈科目B〉



出題数：12問（全問解答必須）

試験時間：120分（両科目）

問49

解説 p.547

A社は、放送会社や運輸会社向けに広告制作ビジネスを展開している。A社は、人事業務の効率化を図るべく、人事業務の委託を検討することにした。A社が委託する業務（以下、B業務という）を図1に示す。

- 採用予定者から郵送されてくる入社時の誓約書、前職の源泉徴収票などの書類をPDFファイルに変換し、ファイルサーバに格納する。
（省略）

図1 B業務

委託先候補のC社は、B業務について、次のようにA社に提案した。

- B業務だけに従事する専任の従業員を割り当てる。
- B業務では、図2の複合機のスキャン機能を使用する。

- スキャン機能を使用する際は、従業員ごとに付与した利用者IDとパスワードをパネルに入力する。
- スキャンしたデータをPDFファイルに変換する。
- PDFファイルを従業員ごとに異なる鍵で暗号化して、電子メールに添付する。
- スキャンを実行した本人宛てに電子メールを送信する。
- PDFファイルが大きい場合は、PDFファイルを添付する代わりに、自社の社内ネットワーク上に設置したサーバ（以下、Bサーバという）に自動的に保存し、保存先のURLを電子メールの本文に記載して送信する。

図2 複合機のスキャン機能（抜粋）

A社は、C社と業務委託契約を締結する前に、秘密保持契約を締結して、C社を訪問し、業務委託での情報セキュリティリスクの評価を実施した。その結果、図3の発見があった。

- 複合機のスキャン機能では、電子メールの差出人アドレス、件名、本文及び添付ファイル名を初期設定¹⁾の状態で使用しており、誰がスキャンを実行しても同じである。
- 複合機のスキャン機能の初期設定情報はベンダーのWebサイトで公開されており、誰でも閲覧できる。

注¹⁾ C社の情報システム部だけが複合機の初期設定を変更可能である。

図3 発見事項

そこで、A社では、初期設定の状態のままではA社にとって情報セキュリティリスクがあり、対策が必要であると評価した。

設問 対策が必要であるとA社が評価した情報セキュリティリスクはどれか。解答群のうち、最も適切なものを選び。

解答群

- ア B業務に従事する従業員が、B業務に従事する他の従業員になりすまして複合機のスキャン機能を使用し、PDFファイルを取得して不正に持ち出す。その結果、A社の採用予定者の個人情報が漏えいする。
- イ B業務に従事する従業員が、攻撃者からの電子メールを複合機からのものと信じて本文中にあるURLをクリックし、攻撃者が用意したWebサイトにアクセスしてマルウェア感染する。その結果、A社の採用予定者の個人情報が漏えいする。
- ウ 攻撃者が、複合機から送信される電子メールを盗聴し、添付ファイルを暗号化して身代金を要求する。その結果、A社が復号鍵を受け取るために多額の身代金を支払うことになる。
- エ 攻撃者が、複合機から送信される電子メールを盗聴し、本文に記載されているURLをSNSに公開する。その結果、A社の採用予定者の個人情報が漏えいする。

A社は、分析・計測機器などの販売及び機器を利用した試料の分析受託業務を行う分析機器メーカーである。A社では、図1の“情報セキュリティリスクアセスメント手順”に従い、年一度、情報セキュリティリスクアセスメントの結果をまとめている。

- 情報資産の機密性、完全性、可用性の評価値は、それぞれ0～2の3段階とし、表1のとおりとする。
- 情報資産の機密性、完全性、可用性の評価値の最大値を、その情報資産の重要度とする。
- 脅威及び脆弱性の評価値は、それぞれ0～2の3段階とする。
- 情報資産ごとに、様々な脅威に対するリスク値を算出し、その最大値を当該情報資産のリスク値として情報資産管理台帳に記載する。ここで、情報資産の脅威ごとのリスク値は、次の式によって算出する。
$$\text{リスク値} = \text{情報資産の重要度} \times \text{脅威の評価値} \times \text{脆弱性の評価値}$$
- 情報資産のリスク値のしきい値を5とする。
- 情報資産ごとのリスク値がしきい値以下であれば受容可能なリスクとする。
- 情報資産ごとのリスク値がしきい値を超えた場合は、保有以外のリスク対応を行うことを基本とする。

図1 情報セキュリティリスクアセスメント手順

表1 情報資産の機密性、完全性、可用性の評価基準

評価値	評価基準	該当する情報の例
機密性	2 法律で安全管理措置が義務付けられている。	- 健康診断の結果、保健指導の記録 - 給与所得の源泉徴収票
	2 取引先から守秘義務の対象として指定されている。	- 取引先から秘密と指定されて受領した資料 - 取引先の公開前の新製品情報
	2 自社の営業秘密であり、漏えいすると自社に深刻な影響がある。	- 自社の独自技術、ノウハウ - 取引先リスト - 特許出願前の発明情報
	1 関係者外秘情報又は社外秘情報である。	- 見積書、仕入価格など取引先や顧客との取引に関する情報 - 社内規程、事務処理要領
	0 公開情報である。	自社製品カタログ、自社Webサイト掲載情報
完全性	2 法律で安全管理措置が義務付けられている。	- 健康診断の結果、保健指導の記録 - 給与所得の源泉徴収票
	2 改ざんされると自社に深刻な影響、又は取引先や顧客に大きな影響がある。	- 社内規程、事務処理要領 - 自社の独自技術、ノウハウ - 設計データ（原本）
	1 改ざんされると事業に影響がある。	- 受発注情報、決済情報、契約情報 - 設計データ（印刷物）
	0 改ざんされても事業に影響はない。	廃版製品カタログデータ
可用性	（省略）	

A社は、自社のWebサイトをインターネット上に公開している。A社のWebサイトは、自社が取り扱う分析機器の情報を画像付きで一覧表示する機能を有しており、主にA社で販売する分析機器に関する機能の説明や操作マニュアルを掲載している。A社で分析機器を購入した顧客は、A社のWebサイトからマニュアルをダウンロードして利用することが多い。A社のWebサイトは、製品を販売する機能を有していない。

A社は、年次の情報セキュリティリスクアセスメントの結果を、表2にまとめた。

表2 A社の情報セキュリティリスクアセスメント結果（抜粋）

情報資産名称	説明	機密性の評価値	完全性の評価値	可用性の評価値	情報資産の重要度	脅威の評価値	脆弱性の評価値	リスク値
社内規程	行動規範や判断基準を含めた社内ルール	1	2	1	2	1	1	2
設計データ（印刷物）	A社における主力製品の設計図	（省略）						
自社Webサイトにあるコンテンツ	分析機器の情報	a1	a2	2	a3	2	2	a4

設問 表2中の a1 ～ a4 に入れる数値の適切な組み合わせを、aに関する解答群から選べ。

aに関する解答群

	a1	a2	a3	a4
ア	0	0	2	8
イ	0	1	2	8
ウ	0	2	1	4
エ	0	2	2	8
オ	1	0	2	4
カ	1	1	2	8
キ	1	2	1	4
ク	1	2	2	8

A社は、金属加工を行っている従業員50名の企業である。同業他社がサイバー攻撃を受けたというニュースが増え、A社の社長は情報セキュリティに対する取組が必要であると考え、新たに情報セキュリティリーダーをおくことにした。

社長は、どのような取組が良いかを検討するよう、情報セキュリティリーダーに任命されたB主任に指示した。B主任は、調査の結果、IPAが実施しているSECURITY ACTIONへの取組を社長に提案した。

SECURITY ACTIONとは、中小企業自らが、情報セキュリティ対策に取り組むことを自己宣言する制度であるとの説明を受けた社長は、SECURITY ACTIONの一つ星を宣言するために情報セキュリティ5か条に取り組むことを決め、B主任に、情報セキュリティ5か条への自社での取組状況を評価するように指示した。

B主任の評価結果は表1のとおりであった。

表1 B主任の評価結果

情報セキュリティ5か条		評価結果
1	OSやソフトウェアは常に最新の状態にしよう！	一部のPCについて実施している
2	(省略)	(省略)
3	パスワードを強化しよう！	(省略)
4	共有設定を見直そう！	(省略)
5	脅威や攻撃の手口を知ろう！	(省略)

表1中の1の評価結果についてB主任は、次のとおり説明した。

- A社が従業員にPCを貸与する時に導入したOSとA社の業務で利用しているソフトウェア（以下、標準ソフトという）は、自動更新機能を使用して最新の状態に更新している。
- それ以外のソフトウェア（以下、非標準ソフトという）はどの程度利用されているかわからないので、試しに数台のPCを確認したところ、大半のPCで利用されていた。最新の状態に更新されていないPCも存在した。

A社では表1中の1について評価結果を“実施している”にするために新たに追加すべき対策として2案を考え、どちらかを採用することにした。

設問 表1中の1の評価結果を“実施している”にするためにA社で新たに追加すべき対策として考えられるものは次のうちどれか。考えられる対策だけを全て挙げた組合せを、解答群の中から選べ。

- (一) PC上のプロセスの起動・終了を記録するEndpoint Detection and Response (EDR) の導入
- (二) PCのOS及び標準ソフトを最新の状態に更新するという設定ルールの導入
- (三) 全てのPCへの脆弱性^{ぜい}修正プログラムの自動適用を行うIT資産管理ツールの導入
- (四) 非標準ソフトのインストール禁止及び強制アンインストール
- (五) ログデータを一括管理、分析して、セキュリティ上の脅威を発見するためのSecurity Information and Event Management (SIEM) の導入

解答群

- | | | |
|------------|------------|------------|
| ア (一), (二) | イ (一), (三) | ウ (一), (四) |
| エ (一), (五) | オ (二), (三) | カ (二), (四) |
| キ (二), (五) | ク (三), (四) | ケ (三), (五) |
| コ (四), (五) | | |

問52

解説 p.550

A社は、複数の子会社を持つ食品メーカーであり、在宅勤務に適用するPCセキュリティ規程（以下、A社PC規程という）を定めている。

A社は、20XX年4月1日に同業のB社を買収して子会社にした。B社は、在宅勤務できる日数の上限を週2日とした在宅勤務制度を導入しており、全ての従業員が利用している。

B社は、A社PC規程と同様の規程を作成して順守することにした。B社は、自社の規程の作成に当たり、表1のとおりA社PC規程への対応状況の評価結果を取りまとめた。

表1 A社PC規程へのB社の対応状況の評価結果（抜粋）

項番	A社PC規程	評価結果
1	(省略)	OK
2	(省略)	OK
3	会社が許可したアプリケーションソフトウェアだけを導入できるように技術的に制限すること	NG
4	外部記憶媒体へのアクセスを技術的に禁止すること	NG ¹⁾
5	Bluetoothの利用を技術的に禁止すること	NG

注記 評価結果が“OK”とはA社PC規程を満たす場合，“NG”とは満たさない場合をいう。

注¹⁾ B社は、外部記憶媒体へのアクセスのうち、外部記憶媒体に保存してあるアプリケーションソフトウェア及びファイルのNPCへのコピーだけは許可している。

評価結果のうち、A社PC規程を満たさない項番については、必要な追加対策を実施することによって、情報セキュリティリスクを低減することにした。

設問 表1中の項番4について、B社が必要な追加対策を実施することによって低減できる情報セキュリティリスクは次のうちどれか。低減できるものだけを全て挙げた組合せを、解答群の中から選べ。ここで、項番3、5への追加対策は実施しないものとする。

- (一) B社で許可していないアプリケーションソフトウェアが保存されている外部記憶媒体がNPCに接続された場合に、当該NPCがマルウェア感染する。
- (二) 外部記憶媒体がNPCに接続された場合に、当該外部記憶媒体に当該NPC内のデータを保存して持ち出される。
- (三) マルウェア付きのファイルが保存されている外部記憶媒体がNPCに接続された場合に、当該NPCがマルウェア感染する。
- (四) マルウェアに感染しているNPCに外部記憶媒体が接続された場合に、当該外部記憶媒体がマルウェア感染する。

解答群

- | | |
|-----------------|-----------------|
| ア (一), (二) | イ (一), (二), (三) |
| ウ (一), (二), (四) | エ (一), (三) |
| オ (一), (四) | カ (二), (三) |
| キ (二), (四) | ク (三), (四) |

A社は、高級家具を販売する企業である。A社は2年前に消費者に直接通信販売する新規事業を開始した。それまでA社は、個人情報ほとんど取り扱っていなかったが、通信販売事業を開始したことによって、複合機で印刷した送り状など、顧客の個人情報を大量に扱うようになってきた。そのため、オフィス内に通販事業部エリアを設け、個人情報が漏えいしないよう対策した。具体的には、通販事業部エリアの出入口に、ICカード認証でドアを解錠するシステムを設置し、通販事業部の従業員だけが通販事業部エリアに入退室できるようにした。他のエリアはA社の全従業員が自由に利用できるようにしている。図1は、A社のオフィスのレイアウトである。

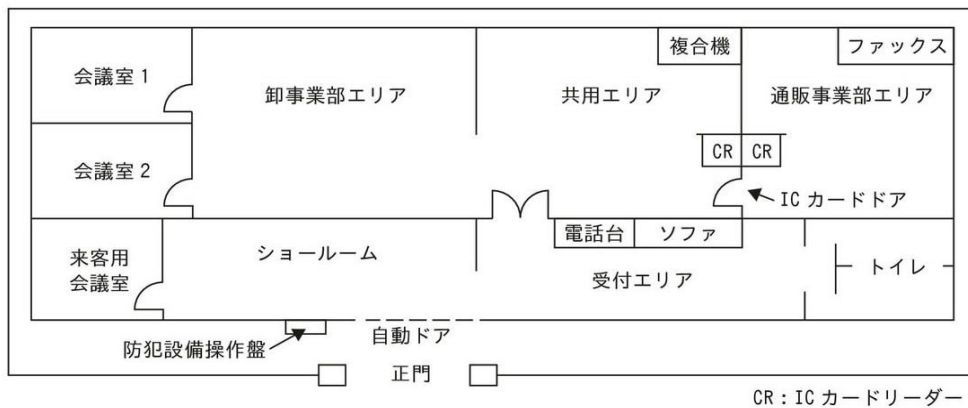


図1 A社のオフィスのレイアウト

このレイアウトでの業務を観察したところ、通販事業部エリアへの入室時に、A社の従業員同士による共連れが行われているという問題点が発見され、改善案を考えることになった。

設問 改善案として適切なものだけを全て挙げた組合せを、解答群の中から選べ。

- (一) ICカードドアに監視カメラを設置し、1年に1回監視カメラの映像をチェックする。
- (二) ICカードドアの脇に、共連れのもたらしリスクを知らせる標語を掲示する。
- (三) ICカードドアを、AESの暗号方式を用いたものに変更する。
- (四) ICカードの認証に加えて指静脈認証も行うようにする。
- (五) 正門内側の自動ドアに共連れ防止用のアンチパスバックを導入する。
- (六) 通販事業部エリア内では、従業員証を常に見えるところに携帯する。
- (七) 共連れを発見した場合は従業員同士で個別に注意する。

解答群

- | | | |
|------------|------------|------------|
| ア (一), (二) | イ (一), (四) | ウ (一), (五) |
| エ (二), (三) | オ (二), (七) | カ (三), (六) |
| キ (三), (七) | ク (四), (六) | ケ (五), (六) |
| コ (五), (七) | | |

サンプル問題

〈科目B〉

問54

解説 p.552

A社は旅行商品を販売しており、業務の中で顧客情報を取り扱っている。A社が保有する顧客情報は、A社のファイルサーバ1台に保存されている。ファイルサーバは、顧客情報を含むフォルダにある全てのファイルを磁気テープに毎週土曜日にバックアップするよう設定されている。バックアップは2世代分が保存され、ファイルサーバの隣にあるキャビネットに保管されている。

A社では年に一度、情報セキュリティに関するリスクの見直しを実施している。情報セキュリティリーダーであるE主任は、A社のデータ保管に関するリスクを見直して図1にまとめた。

1. ランサムウェアによってデータが暗号化され、最新のデータが利用できなくなることによって、最大1週間分の更新情報が失われる。
2. (省略)
3. (省略)
4. (省略)

図1 A社のデータ保管に関するリスク（抜粋）

E主任は、図1の1に関するリスクを現在の対策よりも、より低減するための対策を検討した。

設問 E主任が検討した対策はどれか。解答群のうち、最も適切なものを選び。

解答群

- ア 週1回バックアップを取得する代わりに、毎日1回バックアップを取得して7世代分保存する。
- イ バックアップ後に磁気テープの中のファイルのリストと、ファイルサーバのバックアップ対象フォルダ中のファイルのリストを比較し、差分がないことを確認する。
- ウ バックアップに利用する磁気テープ装置を、より高速な製品に交換する。
- エ バックアップ用の媒体を磁気テープからハードディスクに変更する。
- オ バックアップを二組み取得し、うち一組みを遠隔地に保管する。
- カ ファイルサーバにマルウェア対策ソフトを導入する。

問55

解説 p.553

A社は、SaaS形式の給与計算サービス（以下、Aサービスという）を法人向けに提供する、従業員100名のIT会社である。A社は、自社でもAサービスを利用している。A社の従業員は、WebブラウザでAサービスのログイン画面にアクセスし、Aサービスのアカウント（以下、Aアカウントという）の利用者ID及びパスワードを入力する。ログインに成功すると、自分の給与及び賞与の確認、パスワードの変更などができる。利用者IDは、個人ごとに付与した不規則な8桁の番号である。ログイン時にパスワードを連続して5回間違えるとAアカウントはロックされる。ロックを解除するためには、Aサービスの解除画面で申請する。

A社は、半年に1回、標的型攻撃メールへの対応訓練（以下、H訓練という）を実施しており、表1に示す20XX年下期のH訓練計画案が経営会議に提出された。

表1 20XX年下期のH訓練計画案（抜粋）

項目	内容
電子メールの送信日時	次の日時に、H訓練の電子メールを全従業員宛に送信する。 ・20XX年10月1日 10時00分
送信者メールアドレス	Aサービスを装ったドメインのメールアドレス
電子メールの本文	次を含める。 ・Aアカウントはロックされていること ・ロックを解除するには、次のURLにアクセスすること ・偽解除サイトのURL
偽解除サイト	・氏名、所属部門名並びにAアカウントの利用者ID及びパスワードを入力させる。 ・全ての項目の入力が完了すると、H訓練であることを表示する。
結果の報告	経営会議への報告予定日：20XX年10月31日

注記 偽解除サイトで入力された情報は、保存しない。A社は、従業員の氏名、所属部門名及びAアカウントの情報を個人情報としている。

経営会議では、表1の計画案はどのような標的型攻撃メールを想定しているのかという質問があった。

設問 表1の計画案が想定している標的型攻撃メールはどれか。解答群のうち、最も適切なものを選べ。

解答群

- ア 従業員をAサービスに誘導し、Aアカウントのロックが解除されるかを試行する標的型攻撃メール
- イ 従業員を攻撃者が用意したWebサイトに誘導し、Aアカウントがロックされない連続失敗回数の上限を発見する標的型攻撃メール
- ウ 従業員を攻撃者が用意したWebサイトに誘導し、従業員の個人情報を不正に取得する標的型攻撃メール
- エ 複数の従業員をAサービスに同時に誘導し、アクセスを集中させることによって、一定期間、Aサービスを利用不可にする標的型攻撃メール

A社は学習塾を経営している会社であり、全国に50の校舎を展開している。A社には、教務部、情報システム部、監査部などがある。学習塾に通う又は通っていた生徒（以下、塾生という）の個人データは、学習塾向けの管理システム（以下、塾生管理システムという）に格納している。塾生管理システムのシステム管理は情報システム部が行っている。塾生の個人データ管理業務と塾生管理システムの概要を図1に示す。

- 教務部員は、入塾した塾生及び退塾する塾生の登録、塾生プロフィールの編集、模試結果の登録、進学先の登録など、塾生の個人データの入力、参照及び更新を行う。
- 教務部員が使用する端末は教務部の共用端末である。
- 塾生管理システムへのログインには利用者IDとパスワードを利用する。
- 利用者IDは個人別に発行されており、利用者IDの共用はしていない。
- 塾生管理システムの利用者のアクセス権限には参照権限及び更新権限の2種類がある。参照権限があると塾生の個人データを参照できる。更新権限があると塾生の個人データの参照、入力及び更新ができる。アクセス権限は塾生の個人データごとに設定できる。
- 教務部員は、担当する塾生の個人データの更新権限をもっている。担当しない塾生の個人データの参照権限及び更新権限はもっていない。
- 共用端末のOSへのログインには、共用端末の識別子（以下、端末IDという）とパスワードを利用する。
- 共用端末のパスワード及び塾生管理システムの利用者のアクセス権限は情報システム部が設定、変更できる。

図1 塾生の個人データ管理業務と塾生管理システムの概要

教務部は、今年実施の監査部による内部監査の結果、Webブラウザに塾生管理システムの利用者IDとパスワードを保存しており、情報セキュリティリスクが存在するとの指摘を受けた。

設問 監査部から指摘された情報セキュリティリスクはどれか。解答群のうち、最も適切なものを選べ。

解答群

- ア 共用端末と塾生管理システム間の通信が盗聴される。
- イ 共用端末が不正に持ち出される。
- ウ 情報システム部員によって塾生管理システムの利用者のアクセス権限が不正に変更される。
- エ 教務部員によって共用端末のパスワードが不正に変更される。
- オ 塾生の個人データがアクセス権限をもたない教務部員によって不正にアクセスされる。

問57

解説 p.555

サンプル問題
〈科目B〉

A社は従業員600名の投資コンサルティング会社である。東京の本社には、情報システム部、監査部などの管理部門があり、関西にB支店がある。B支店の従業員は10名である。

B支店では、情報システム部が運用管理しているファイルサーバを使用しており、顧客情報を含むファイルを一時的に保存する場合がある。その場合、ファイルのアクセス権は、当該ファイルを保存した従業員が最小権限の原則に基づいて設定する。今年、B支店では、従業員にヒアリングを行い、ファイルのアクセス権がそのとおりに設定されていることを確認した。

〔自己評価の実施〕

A社では、1年に1回、監査部が各部門に、評価項目を記載したシート（以下、自己評価シートという）を配布し、自己評価の実施と結果の提出を依頼している。

B支店で情報セキュリティリーダーを務めるC氏は、監査部から送付されてきた自己評価シートに従って、職場の状況を観察したり、従業員にヒアリングしたりして評価した。自己評価シートの評価結果は図1の判定ルールに従って記入する。C氏が作成したB支店の評価結果を表1に示す。

- 評価項目どおりに実施している場合：“OK”
- 評価項目どおりには実施していないが、代替コントロールによって、“OK”の場合と同程度にリスクが低減されていると考えられる場合：“(OK)”（代替コントロールを具体的に評価根拠欄に記入する。）
- 評価項目どおりには実施しておらず、かつ、代替コントロールによって評価項目に関するリスクが抑えられていないと考えられる場合：“NG”
- 評価項目に関するリスクがそもそも存在しない場合：“NA”

図1 評価結果の判定ルール

表1 B支店の評価結果（抜粋）

No.	評価項目	評価結果	評価根拠
10	(省略)	OK	(省略)
19	ファイルサーバ上の顧客情報のアクセス権は最小権限の原則に基づいて設定されている。	a	
25	(省略)	OK	(省略)

設問 表1中の a に入れる字句はどれか。解答群のうち、最も適切なものを選べ。

aに関する解答群

	評価結果	評価根拠
ア	OK	アクセス権の設定状況が適切であることを確認した。
イ	OK	アクセス権を適切に設定するルールが存在することを確認した。
ウ	OK	ファイルサーバは情報システム部が運用管理している。
エ	NA	顧客情報をファイルサーバに保存することは禁止されている。

国内外に複数の子会社をもつA社では、インターネットに公開するWebサイトについて、A社グループの脆弱性診断基準（以下、A社グループ基準という）を設けている。A社の子会社であるB社は、会員向けに製品を販売するWebサイト（以下、B社サイトという）を運営している。B社サイトは、会員だけがB社の製品やサービスを検索できる。会員の氏名、メールアドレスなどの会員情報も管理している。

B社では、11月に情報セキュリティ活動の一環として、A社グループ基準を基に自己点検を実施し、その結果を表1のとおりまとめた。

表1 B社自己点検結果（抜粋）

項番	点検項目	A社グループ基準	点検結果
(一)	Webアプリケーションプログラム（以下、Webアプリという）に対する脆弱性診断の実施	- インターネットに公開しているWebサイトについて、Webアプリの新規開発時、及び機能追加時に行う。 - 機能追加などの変更がない場合でも、年1回以上行う。	3年前にB社サイトをリリースする1か月前に、Webアプリに対する脆弱性診断を行った。リリース以降は実施していない。 3年前の脆弱性診断では、軽微な脆弱性が2件検出された。
(二)	OS及びミドルウェアに対する脆弱性診断の実施	インターネットに公開しているWebサイトについて、年1回以上行う。	- 毎年4月及び10月に、B社サイトに対して行っている。 - 今年4月の脆弱性診断では、脆弱性が3件検出された。
(三)	脆弱性診断結果の報告	Webアプリ、OS及びミドルウェアに対する脆弱性診断を行った場合、その結果を、診断後2か月以内に各社の情報セキュリティ委員会に報告する。	3年前にWebアプリに対する脆弱性診断を行った2週間後に、結果を情報セキュリティ委員会に報告した。 - OS及びミドルウェアに対する脆弱性診断の結果は、4月と10月それぞれの月末の情報セキュリティ委員会に報告した。
(四)	脆弱性診断結果の対応	Webアプリ、OS及びミドルウェアに対する脆弱性診断で、脆弱性が発見された場合、緊急を要する脆弱性については、速やかに対応し、その他の脆弱性については、診断後、1か月以内に対応する。指定された期限までの対応が困難な場合、対応の時期を明確にし、最高情報セキュリティ責任者（CISO）の承認を得る。	3年前に検出したWebアプリの脆弱性2件について、B社サイトのリリースの1週間前に対応した。 - 今年4月に検出したOS及びミドルウェアに対する脆弱性のうち、2件は翌日に対応した。残り1件は、恒久的な対策は来年1月のB社サイトの更改時に対応するものとし、それまでは、設定変更による暫定対策をとるという対応計画について、脆弱性診断の10日後にCISOの承認を得た。

設問 表1中の自己点検の結果のうち、A社グループ基準を満たす項番だけを全て挙げた組合せを、解答群の中から選べ。

解答群

- | | |
|----------------------|-----------------|
| ア (一), (二) | イ (一), (二), (三) |
| ウ (一), (二), (三), (四) | エ (一), (二), (四) |
| オ (一), (三), (四) | カ (一), (四) |
| キ (二), (三) | ク (二), (三), (四) |
| ケ (三), (四) | |

問59

解説 p.557

A社は従業員200名の通信販売業者である。一般消費者向けに生活雑貨、ギフト商品などの販売を手掛けている。取扱商品の一つである商品Zは、Z販売課が担当している。

〔Z販売課の業務〕

現在、Z販売課の要員は、商品Zについての受注管理業務及び問合せ対応業務を行っている。商品Zについての受注管理業務の手順を図1に示す。

商品Zの顧客からの注文は電子メールで届く。

(1) 入力

販売担当者は、届いた注文（変更，キャンセルを含む）の内容を受注管理システム¹⁾（以下，Jシステムという）に入力し，販売責任者²⁾に承認を依頼する。

(2) 承認

販売責任者は，注文の内容とJシステムへの入力結果を突き合わせて確認し，問題がなければ承認する。問題があれば差し戻す。

注¹⁾ A社情報システム部が運用している。利用者は，販売責任者，販売担当者などである。

注²⁾ Z販売課の課長1名だけである。

図1 受注管理業務の手順

〔Jシステムの操作権限〕

Z販売課では、Jシステムについて、次の利用方針を定めている。

〔方針1〕 ある利用者が入力した情報は、別の利用者が承認する。

〔方針2〕 販売責任者は、Z販売課の全業務の情報を閲覧できる。

Jシステムでは、業務上必要な操作権限を利用者に与える機能が実装されている。

この度、商品Zの受注管理業務が受注増によって増えていることから、B社に一部を委託することにした（以下、商品Zの受注管理業務の入力作業を行うB社従業員を商品ZのB社販売担当者といい、商品ZのB社販売担当者の入力結果をチェックするB社従業員を商品ZのB社販売責任者という）。

委託に当たって、Z販売課は情報システム部にJシステムに関する次の要求事項を伝えた。

〔要求1〕 B社が入力した場合は、A社が承認する。

〔要求2〕 A社の販売担当者が入力した場合は、現状どおりにA社の販売責任者が承認する。

上記を踏まえ、情報システム部は今後の各利用者に付与される操作権限を表1にまとめた。

表1 操作権限案

利用者 付与される操作権限	Jシステム		
	閲覧	入力	承認
a	○		○
(省略)	○	○	
(省略)	○		
(省略)	○	○	

注記 ○は、操作権限が付与されることを示す。

設問 表1中の a に入れる適切な字句を解答群の中から選べ。

解答群

- ア Z販売課の販売責任者
- イ Z販売課の販売担当者
- ウ Z販売課の要員
- エ 商品ZのB社販売責任者
- オ 商品ZのB社販売担当者

問60

解説 p.557

A社は輸入食材を扱う商社である。ある日、経理課のB課長は、A社の海外子会社であるC社のDさんから不審な点がある電子メール（以下、メールという）を受信した。B課長は、A社の情報システム部に調査を依頼した。A社の情報システム部がC社の情報システム部と協力して調査した結果を図1に示す。

- 1 B課長へのヒアリング並びに受信したメール及び添付されていた請求書からは、次が確認された。
 - [項番1] Dさんが早急な対応を求めたことは今まで1回もなかったが、メール本文では送金先の口座を早急に変更するよう求めている。
 - [項番2] 添付されていた請求書は、A社がC社に支払う予定で進めている請求書であり、C社が3か月前から利用を開始したテンプレートを利用したものだった。
 - [項番3] 添付されていた請求書は、振込先が、C社が所在する国ではない国にある銀行の口座だった。
 - [項番4] 添付されていた請求書が作成されたPCのタイムゾーンは、C社のタイムゾーンとは異なっていた。
 - [項番5] メールを送信者（From）のメールアドレスには、C社のドメイン名とは別の類似するドメイン名が利用されていた。
 - [項番6] メールの返信先（Reply-To）はDさんのメールアドレスではなく、フリーメールのものであった。
 - [項番7] メール本文では、B課長とDさんとの間で6か月前から何度かやり取りしたメールの内容を引用していた。
- 2 不正ログインした者が、以降のメール不正閲覧の発覚を避けるために実施したと推察される設定変更がDさんのメールアカウントに確認された。

図1 調査の結果（抜粋）

設問 B課長に疑いをもたれないようにするためにメールの送信者が使った手口として考えられるものはどれか。図1に示す各項番のうち、該当するものだけを全て挙げた組合せを、解答群の中から選べ。

解答群

- | | |
|-----------------------|-----------------------|
| ア [項番1], [項番2], [項番3] | イ [項番1], [項番2], [項番6] |
| ウ [項番1], [項番4], [項番6] | エ [項番1], [項番4], [項番7] |
| オ [項番2], [項番3], [項番6] | カ [項番2], [項番5], [項番7] |
| キ [項番3], [項番4], [項番5] | ク [項番3], [項番5], [項番7] |
| ケ [項番4], [項番5], [項番6] | コ [項番5], [項番6], [項番7] |